



CERTIFICATION PRACTICE PAPER

Data Protection Officer Practice Examination

A realistic 4-hour mock paper with full answer key, modelled on the POTRAZ / HIT certification examination. Unofficial practice material.

Document Practice Exam

Standard Cyber & Data Protection Act [Chapter 12:07] · SI 155 of 2024

Prepared with VAKA OS

Modelled on the POTRAZ/HIT 4-hour written examination. This is an unofficial practice paper written from the Cyber and Data Protection Act [Chapter 12:07] and SI 155 of 2024. It is *not* a copy of the real exam — no official paper is published — but it drills the same material. Answer key is in a separate section at the bottom; cover it while you sit the paper.

Time allowed: 4 hours **Total:** 100 marks **Instructions:** Answer ALL questions in Sections A, B and C. Cite the instrument and section where you can.

SECTION A — Short answer (30 marks)

1. Name the statute that is the primary source of data protection law in Zimbabwe, including its chapter number. (2)
2. Which body is the designated Data Protection Authority? (1)
3. Define "data controller" and "data processor" and state the key difference. (4)
4. List the seven data protection principles. (7)
5. Define "biometric data" and give three examples from SI 155. (4)
6. State the four licence tiers and the range of data subjects for each. (4)
7. Within how many hours must a data controller report a personal data breach to POTRAZ, and on which form? (2)
8. List any four functions of a Data Protection Officer under SI 155 s.14. (4)
9. What is the penalty for failing to appoint a DPO, and how does it differ from most other penalties in the regulations? (2)

SECTION B — Structured / applied questions (40 marks)

1. A private hospital processes health records for about 120,000 patients. (12) a. Which licence tier applies and what is the initial licence fee? (3) b. Health data is a special category — what extra obligations arise (name at least three)? (4) c. The hospital has never appointed a DPO. State the offence and penalty, and the deadline it missed. (3) d. Name two forms the hospital must file with POTRAZ and what each is for. (2)
 2. A fintech app suffers a cyber-attack; 40,000 customers' ID numbers and bank details are exposed. (14) a. Set out the complete breach-notification timeline the DPO must follow, with each deadline. (6) b. Which principle(s) were most likely breached, and why? (4) c. What records and procedures should have been in place beforehand? (4)
 3. A marketing company buys a list of 5,000 people's contact details and emails them ads without their knowledge. (14) a. Identify the lawful-basis and principle problems. (6) b. Which data subject rights are engaged? (4) c. Advise the company on how to become compliant. (4)
-

SECTION C — Essay / discussion (30 marks)

1. Answer **ONE** of the following in essay form. (30)

EITHER (a) "The DPO advises and monitors, but the controller remains accountable." Discuss the role, independence, qualifications and functions of a Data Protection Officer under Zimbabwean law, and explain how a DPO builds a culture of compliance in an organisation.

OR (b) Explain the licensing regime for data controllers under SI 155 of 2024 — who must be licensed, the exemptions, the tiers and fees, the timelines, and the consequences of non-compliance — and critically assess whether the regime adequately protects data subjects.

Answer Key

Cover this section until you have completed the paper.

Section A

1. **Cyber and Data Protection Act [Chapter 12:07]** (Act 5 of 2021). (2)
2. **POTRAZ** — the Postal and Telecommunications Regulatory Authority of Zimbabwe. (1)
3. **Controller** determines the *purposes and means* of processing; **processor** processes on the controller's behalf. Difference: the controller *decides*, the processor *acts on instructions*. Controller carries primary legal accountability. (4)
4. Lawfulness/fairness/transparency; purpose limitation; data minimisation; accuracy; storage limitation; integrity & confidentiality (security); accountability. (7)
5. Physiological characteristics related to a data subject; examples: **fingerprints, palm veins, face recognition**. (4)
6. Tier 1: 50–1,000; Tier 2: 1,001–100,000; Tier 3: 100,001–500,000; Tier 4: >500,000. (4)
7. **24 hours**, on **Form DP3**. (2)
8. Any four of: monitor compliance (incl. audits, training, awareness); handle POTRAZ and data-subject requests; advise employees on obligations; advise on and monitor DPIAs; liaise with POTRAZ; act as contact point for data subjects. (4)
9. Failing to appoint a DPO: **level 7 fine and/or up to 2 years**. It is *lower* than the level-11 / 7-year penalty attached to most other contraventions. (2)

Section B

1. **Hospital (120,000 patients)** a. **Tier 3** (100,001–500,000); initial licence fee **USD 500** (application fee USD 30). (3) b. Any three: explicit/stronger lawful basis for sensitive data; heightened security measures; DPIAs; stricter access controls; notify POTRAZ that sensitive/health data is processed; data-subject safeguards. (4) c. Offence of failing to appoint a DPO — **level 7 and/or up to 2 years**; should have appointed within **90 days** of promulgation. (3) d. **Form DP1** (controller licence application/renewal) and **Form DP2** (DPO appointment notification). (2)
2. **Fintech breach** a. Report to **POTRAZ within 24 hours** (Form DP3) → notify affected **data subjects within 72 hours** (high risk) → respond to POTRAZ info requests within **14 days** → conclude investigation and submit report within **21 days**; keep a record of the breach throughout. (6) b. **Security/integrity & confidentiality** (inadequate protection of sensitive financial/ID data); arguably **accountability** (failure to demonstrate adequate measures). (4) c. Risk assessments, organisational security policies, physical/technical controls, encryption/access control, breach detection & internal reporting procedures, a breach register, and tested restoration/backup. (4)
3. **Marketing company** a. No **lawful basis** (no consent/legitimate-interest balancing); breaches **lawfulness/fairness/transparency, purpose limitation** (data reused for a new purpose), and **minimisation**. (6) b.

Rights to be **informed**, to **object**, to **erasure**, and to **access**. (4) c. Stop processing; establish a lawful basis (obtain valid consent or run a legitimate-interest assessment); provide privacy notices; honour opt-outs/objections; delete unlawfully obtained data; get licensed and appoint a DPO. (4)

Section C (marking guidance)

13a. Credit: qualifications (s.13), functions (s.14, all six), appointment/notification via Form DP2 and timelines (s.12), independence and CPD/annual recertification (s.10(1)), the controller's residual accountability (s.10(4)), and practical culture-building (training, awareness, audits, DPIAs, being the data-subject contact point). Reward citation, structure and applied insight. (30)

13b. Credit: who must be licensed (s.3/s.4), exemptions (s.8 — personal/family, law enforcement, journalistic/historical/archival, with registration duty for the latter two), the four tiers and fees, timelines (14-day decision, 12-month validity, 3-month renewal lead, 6-month transition), penalties (level 11 / 7 years), and a reasoned critique (strengths: risk-tiered, register, enforcement; weaknesses: cost burden, capacity, awareness). Reward balance and citation. (30)

Self-scoring

80–100: exam-ready.

60–79: solid; revise weak areas and re-drill the timelines/penalties.

Below 60: re-read the Study Guide Parts 3–7 and redo this paper in a week.